

BSc (Hons) Computer Science with Software Engineering
Coventry University (CU) - National Institute of Business Management (NIBM)

NB5004CEM - Cybersecurity

Report Writing, Traceability & Viva Preparation



*The final session: assembling the evidence,
defending the decisions.*





S12 Report Writing, Traceability & Viva Preparation



The final session: synthesis and defence. Nothing new mechanically - everything is assembly.

Session Overview



**Write it so it can be defended.
Then defend it.**

- **Write a professional finding: evidence, property, SRS mapping (LO2, LO4)**
- **Build a traceability matrix and identify the gaps (LO2)**
- **Separate executive summary from technical detail (LO1, LO2)**
- **Rehearse the viva under peer challenge (LO1, LO3, LO4)**



What Makes a Finding Professional



- Every control tested in Part B, and every gap found in testing, becomes one thing: a finding
- A finding is not a description of the system - it is a specific, evidenced, actionable claim about one issue
- Seven elements turn an observation into a professional finding - the anatomy on the next slide
- This is the assembly target for the three findings you draft in today's lab

Seven Elements, One Finding



Element	Purpose
Title	Clear, specific - names the vulnerability and affected component
Severity	CVSS score + qualitative label (Critical / High / Medium / Low)
Evidence	What was observed - tool output, screenshot, request/response
Property violated	Which of the five properties is at risk
SRS mapping	Which requirement ID this finding relates to
Business impact	What an attacker could achieve - in the context of this system and industry
Remediation	Specific, actionable recommendation - not generic advice

Evidence, Property and the Domain Lens



- **Evidence is what makes a finding auditable: tool output, a screenshot, or a request/response - not a claim on its own**
- **Property violated names which of the five properties is at risk - never leave it unstated**
- **Business impact translates the issue into what an attacker could achieve, in YOUR assigned domain (Banking, Healthcare, Transport, Education, Ecommerce, Hospitality)**

Analogy

A finding without evidence is like a medical diagnosis without a test result - a plausible claim, not something a second reader can verify or act on.

KEY CONCEPT



Traceability Is What Makes a Report Defensible

SRS Requirement → Control Implemented → Evidence of Control → Residual Risk. Every control in Part B traces back to a requirement in Part A. Every finding traces back to a requirement that failed or was never implemented. Without that chain, a report is a list of observations - not an evaluation.



The Traceability Chain, Worked



- **SRS Requirement: IAM-01 - administrators must authenticate with MFA**
- **Control implemented: TOTP-based MFA enforced on the admin console**
- **Evidence of control: screenshot of the MFA prompt; config extract showing MFA enforced**
- **Residual risk: TOTP secrets sit in the app database - a database compromise still exposes the second factor**

Analogy

Think of it as a chain of custody: each link (requirement, control, evidence, residual risk) has to connect to the next, or the chain - and the report's credibility - breaks.

Traceability Runs Both Ways



- **Forward:** every control described in Part B should trace back to an SRS requirement from Part A
- **Backward:** every finding should trace back to a failed or absent requirement
- A control with no requirement behind it is scope creep - it was not asked for, and it is not evaluated
- A requirement with no control behind it is a gap - today's matrix exercise makes both visible

Coursework hook: B9 - traceability, 10% of marks (shared with S2 diagramming)

Executive Summary vs Technical Detail

Executive Summary

- Answers: what is the overall security posture, and what must be prioritised?
- Written for a reader who will never touch the technical detail
- No mechanisms, no tool output - conclusions and priorities only

Technical Detail

- Provides the evidence: findings, tool output, SRS mapping, remediation
- Written for a reader who wants to verify every claim
- Must be consistent with the executive summary - disagreement contradicts the report

Report Writing: Five Ways It Fails



Failure	Why it fails
Vague language	"The system has poor security" is not a finding
Missing evidence	An assertion without an observation is not auditable
Generic recommendations	"Improve security" is not actionable
Inconsistency	The summary and the findings disagree with each other
Missing SRS traceability	A control described with nothing to connect it to

Coursework hook: writing quality & references, 5% of marks



Viva Preparation



The viva tests understanding and decision-making - not recall.

The Viva: What It Actually Tests



Two Jobs, Not One

“The viva tests understanding and decision-making - not recall.”

The viva does two separate jobs. First, 10% of your marks reward oral defence as a skill in its own right: the clarity of your rationale, how you handle challenge, and how well you explain a trade-off. Second, and separately, the viva verifies that Parts A and B are genuinely your own work and genuinely understood, and it caps your A and B marks at the level of understanding you can demonstrate: defend the work fully and the documentation marks stand in full; where a part cannot be defended, the marks for that part are capped accordingly; where the work appears not to be your own, it is referred under the academic integrity policy rather than silently reduced.

Two separate jobs, two separate facets - that is what avoids double jeopardy.

Grasp, Not Memory



- **The viva checks top-level grasp and conceptual soundness: can you explain why a decision is right, and defend it when challenged**
- **It is not a recitation test - you will not be asked to reproduce your report from memory, word for word**
- **If you understand your own reasoning, you can explain it in different words every time you are asked**

Analogy

It is like explaining a decision to a skeptical colleague, not reciting a script - they do not care about your exact wording, they care whether your reasoning holds up when they push back.

Three Patterns for a Confident Viva

- 
- **Design decision:** "I chose X because [requirement], and it satisfies [property] by [mechanism]. The trade-off is [limitation]."
 - **Trade-off:** "I chose X over Y because X better satisfies [requirement] here, accepting [cost] of X."
 - **Failure scenario:** "If [control] fails, [second control] gives defence in depth. The residual risk is [description], acceptable because [reasoning]."

Analogy

These are sentence templates, not scripts - rehearse the shape of the answer, then fill it with your own system's specifics.

Why Talking About Failure Earns More Credit

- 
- The student who can discuss a failure clearly is demonstrating deeper understanding than the student who only describes what works
 - "If this fails, here is what catches it, and here is the residual risk" shows you understand the control - not just that you added it
 - This is exactly what the peer-viva challenge in today's lab is designed to surface, before the real deadline

Coursework hook: viva, 10% of marks (mandatory)

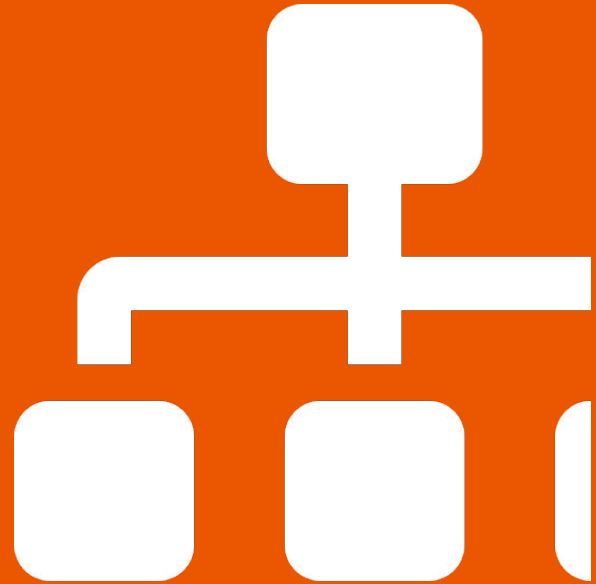
Critique Reports

1. Two example report extracts are provided - one poor, one strong
2. Using the rubric, identify what makes each effective or weak
3. Name the failures precisely: vague language, missing evidence, unsupported severity, no SRS mapping



Build the Matrix

1. You are given a set of SRS requirements and a list of controls
2. Build a traceability matrix: map each requirement to its control and evidence source
3. Mark requirements with no control as a GAP
4. Mark controls with no requirement as SCOPE CREEP



Draft Findings

1. Use your own system and your S9/S10 tool outputs
2. Draft three findings using the seven-element anatomy
3. Map each finding to its SRS requirement
4. Write the business impact for your assigned domain



Peer Viva

1. One student explains one design decision from their Part B
2. The partner challenges: why this control? What if it fails? Does it satisfy your SRS requirement?
3. Swap roles
4. Notice which decisions you cannot yet defend - fix those before the deadline



Try It Yourself: Finding Grader & Traceability Matrix

- 
- Paste one of your drafted findings into the grader - it flags vague language, missing evidence, unsupported severity, and missing SRS mapping
 - Connect requirement to control to evidence in the matrix panel - gaps and scope creep highlight as you build it
 - Runs entirely offline in your browser - open the demo file and try it again before the deadline, not just today
 - Mirrors both of today's activities - use it to self-check every finding you write

Coursework Connection



10%

B9: Traceability

shared with S2 diagramming

5%

Writing Quality & References

clarity, consistency, SRS mapping

10%

Viva (mandatory)

oral defence + understanding cap

You leave with	Detail
Three findings drafted	from your own system, using S9/S10 evidence
Traceability matrix built	gaps and scope creep identified
One decision viva-tested	under real peer challenge

From S1 to S12: The Arc



- **S1-S2 Foundations:** domain assigned, properties and layers named, threat model sketched
- **S3-S7 Mechanisms:** cryptography, IAM, application, network and system controls, layer by layer
- **S8-S11 Method and Evidence:** SRS drafted, tools run, configuration reviewed, resilience and compliance covered
- **S12 Assembly:** findings written, traceability proven, viva rehearsed - the report becomes defensible

Questions & Defence



Bring one decision you are not sure you can defend yet.



Disclaimer & Copyrights



The information presented in this presentation is intended for general informational purposes only. It is not meant to be comprehensive or to constitute professional advice. Any reliance you place on such information is strictly at your own risk. While I strive to keep the information accurate and up-to-date, I do make no representations or warranties of any kind, express or implied, about the completeness, accuracy, reliability, suitability, or availability concerning the content within this presentation.

This presentation may include references or links to third-party websites or content. I do not endorse the views expressed or the information provided on such external sites. I am not responsible for the content of any linked site or any link contained in a linked site.

Any action you take upon the information presented in this presentation is strictly at your own discretion. I will not be liable for any losses or damages in connection with the use of this information.

This disclaimer is subject to change without notice.

© Images and artworks used in this presentation are used for general informational purposes only. It may contain copyrighted material, the use of which may not have been specifically authorised by the copyright owner. This material is available in an effort to explain issues relevant to the topic. This should constitute a 'fair use' of any such copyrighted material.

Last modified: 13 Jul 2026